

TABLE I

SUBJECT SYSTEMS, MODELS, AND COST. UNITS ARE RUNNABLE DEPLOYMENT UNITS (DEPLOYMENT, STATEFULSET, OR COMPOSE SERVICE); EVERY UNIT OF EACH GROUND-TRUTH FILE IS MODELED. RULES: ISOLATION / CONFIDENTIALITY / AUTHENTICATION / AUTHORIZATION / AVAILABILITY. TIME IS THE MEDIAN OF 10 RUNS INCLUDING JVM START-UP.

System	Domain	Format	Ground truth (commit)	Model size			Structure			Rules (I/C/Au/Az/Av)	Cost	
				Units	App	Data	Ext.	Conn.	Links		ms	MB
BoA	Banking	K8s	1e40564	9	7	2	1	13	25	1/1/1/1/1	340	96
HR	Hospitality	Compose	6ecb097	24	12	12	1	42	83	1/0/0/0/2	360	103
OB	E-commerce	K8s	9a4616e	12	11	1	1	17	33	1/1/0/0/2	340	101
OTel	E-commerce	Compose	f7408a5	20	18	2	1	49	97	1/1/0/0/2	335	102
SN	Social	Compose	6ecb097	27	14	13	2	48	94	1/0/0/0/2	340	104
SS	E-commerce	K8s	9dff06f	14	9	5	1	16	31	1/1/0/0/2	330	101
TS	E-commerce	K8s	34b37f7	7	6	1	1	14	27	1/0/1/0/1	325	95
Total	4 domains	4 K8s, 3 Compose		113	77	36	8	199	390	7/4/2/1/12		

TABLE II

FINDINGS PER CHECK AND SYSTEM (45 IN TOTAL). “–” = CHECK NOT APPLICABLE (THE SYSTEM AUTHORS NO RULE OF THAT TYPE); · = CHECKED, NOTHING FOUND (NOT PROOF OF ABSENCE). EACH FINDING WAS CHECKED AGAINST THE SYSTEM’S SOURCE: C = CONFIRMED, P = PARTIAL (EXPOSURE TRUE, THE APP HAS A LOGIN ON SOME ROUTES), D = BY DESIGN (A REAL PATH THE APP NEEDS), A = MODEL ARTIFACT (TRUE IN THE MODEL, NOT A WEAKNESS OF THE APP). $PREC. = C/\Sigma$; $PREC.^+ = (C+P+D)/\Sigma$. PILOT = VULNERABLE/FIXED PAIR THAT EXERCISES THE CHECK.

Check	CWE	Findings per system								Σ	Fired/app.	Verdict				Precision		Pilot
		BoA	HR	OB	OTel	SN	SS	TS	C			P	D	A	Prec.	Prec. ⁺		
<i>Weakness detection (no rule needed)</i>																		
Unauthenticated entry	CWE-306	1	1	1	1	2	1	1	8	7/7	3	4	0	1	38%	88%	c3,c4,c11	
Exposed data store	CWE-668	.	.	.	.	.	.	.	.	0/7	.	.	.	.	—	—	c4	
Unintended exposure	CWE-668	.	.	.	.	.	.	.	.	0/7	.	.	.	.	—	—	c5	
<i>Satisfaction (rule-dependent)</i>																		
Isolation violated	CWE-923	.	.	.	.	1	1	.	2	2/7	1	0	1	0	50%	100%	c2,c8,c11	
Plaintext channel	CWE-319	3	—	1	1	—	1	—	6	4/4	6	0	0	0	100%	100%	c10	
Authentication bypass	CWE-306	.	—	—	—	—	—	1	1	1/2	1	0	0	0	100%	100%	c9	
Insufficient replicas	—	1	4	2	3	12	5	1	28	7/7	28	0	0	0	100%	100%	c1	
No zone spread	—	—	—	—	—	—	—	—	.	—	.	.	.	.	—	—	c1	
<i>Consistency and structure</i>																		
Contradictory policy	—	.	.	.	.	.	.	.	.	0/7	.	.	.	.	—	—	c7	
Access without authn	CWE-306	.	—	—	—	—	—	—	.	0/1	.	.	.	.	—	—	c6	
Vacuous resolution	—	.	.	.	.	.	.	.	.	0/7	.	.	.	.	—	—	c12	
Total		5	5	4	5	15	8	3	45		39	4	1	1	87%	98%	11/11	

TABLE III

MUTATION PILOT: EACH HAND-BUILT PAIR DIFFERS BY ONE ARCHITECTURAL FACT. ✓ = FLAGGED (VULNERABLE) OR CLEAN (FIXED).

Pair	Check exercised	CWE	Vuln.	Fixed
c1	Availability (replicas, zone)	400	✓	✓
c2	Isolation, direct	668	✓	✓
c3	Unauthenticated entry	306	✓	✓
c4	Exposed data store	200	✓	✓
c5	Unintended exposure	668	✓	✓
c6	Access without authn	862	✓	✓
c7	Contradictory policy	–	✓	✓
c8	Isolation, via mediator	–	✓	✓
c9	Authentication, token at target	306	✓	✓
c10	Plaintext channel	319	✓	✓
c11	Isolation, weak-hop chain	923	✓	✓
c12	Vacuous resolution	–	✓	✓
Detection			12/12	12/12

TABLE IV

SUMMARY OF RESULTS PER RESEARCH QUESTION.

RQ	Metric	Result
RQ1 Expressiveness	systems modeled without metamodel change	7/7
	deployables / edges modeled	113 / 191
RQ2 Effectiveness	findings confirmed in source	39/45 (87%)
	confirmed, partial or by design	44/45 (98%)
	model artifacts (not a real weakness)	1/45 (2%)
RQ3 Discrimination	vulnerable flagged / fixed clean	12/12 / 12/12
	checks exercised by the pilot	11/11
RQ4 Cost	time per system (median, ms)	325–360
	peak memory (MB)	95–104